

Task 1 Vulnerability Report

Cybersecurity Internship – Alfido Tech

Submitted by: Sourabh Kumar Singh

Tools Used: Kali Linux, Nmap, Nikto

Target System: Metasploitable 2 Virtual Machine

Target IP Address: 192.168.56.102

1. Objective

The objective of this task was to perform active reconnaissance, port and service enumeration, and vulnerability scanning on a safe and authorized test environment.

The assessment was conducted using a Kali Linux virtual machine as the security testing system and Metasploitable 2 as the intentionally vulnerable target machine. The target was deployed in an isolated VirtualBox Host-Only network.

Nmap was used to identify active hosts, discover open ports, and enumerate services and software versions. Nmap vulnerability scripts were then used to identify potential security weaknesses. Finally, Nikto was used to perform a web server vulnerability assessment.

The purpose of this assessment was to identify security weaknesses, understand the risks associated with exposed services, and recommend appropriate mitigation measures.

2. Test Environment

Component	Details
Assessment Machine	Kali Linux
Target Machine	Metasploitable 2
Kali Linux IP	192.168.56.101
Target IP	192.168.56.102
Network	192.168.56.0/24
Network Type	VirtualBox Host-Only Network
Assessment Type	Authorized Security Assessment
Tools Used	Nmap, Nmap NSE, Nikto

All testing was performed in an isolated and authorized laboratory environment. No unauthorized systems were targeted during this assessment.

3. Methodology

The assessment followed a structured security testing workflow:

1. Lab environment configuration
2. Network connectivity testing
3. Host discovery
4. Full TCP port scanning
5. Service and version enumeration
6. Vulnerability assessment using Nmap NSE scripts
7. Web server vulnerability assessment using Nikto
8. Analysis of findings
9. Risk classification
10. Security recommendations

The overall workflow is shown below:

Lab Setup

↓

Connectivity Testing

↓

Host Discovery

↓

Port Enumeration

↓

Service & Version Detection

↓

Vulnerability Scanning

↓

Web Server Assessment

↓

Risk Analysis

↓

Mitigation Recommendations

4. Network Connectivity Testing

Before beginning the reconnaissance process, connectivity between Kali Linux and the target machine was verified.

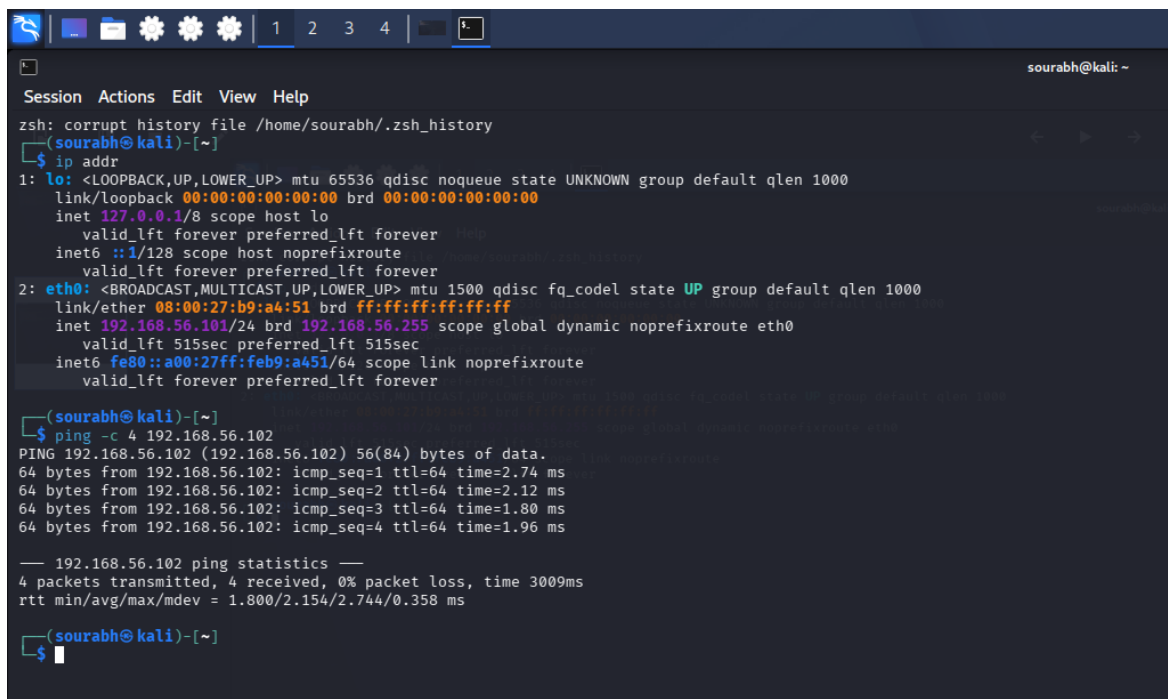
The following command was executed:

```
ping -c 4 192.168.56.102
```

The target successfully responded to all four ICMP packets with no packet loss.

This confirmed that Kali Linux and the Metasploitable 2 machine were successfully connected within the same isolated laboratory network.

Result: Successful connectivity.



```
Session Actions Edit View Help
zsh: corrupt history file /home/sourabh/.zsh_history
(sourabh@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:b9:a4:51 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
        valid_lft 515sec preferred_lft 515sec
    inet6 fe80::a00:27ff:feb9:a451/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(sourabh@kali)-[~]
$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=2.74 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=2.12 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.80 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=1.96 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3009ms
rtt min/avg/max/mdev = 1.800/2.154/2.744/0.358 ms

(sourabh@kali)-[~]
$
```

5. Host Discovery

Host discovery was performed to identify active systems on the isolated laboratory network.

The following command was used:

```
nmap -sn 192.168.56.0/24
```

The scan identified multiple active hosts within the Host-Only network, including the Kali Linux machine and the Metasploitable 2 target.

The target system used for the assessment was identified as:

192.168.56.102

Host discovery was performed before detailed scanning to identify active systems and confirm the authorized target.

```
(sourabh@kali)-[~]
$ nmap -sn 192.168.56.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-21 10:42 +0530
Nmap scan report for 192.168.56.1
Host is up (0.00084s latency).
MAC Address: 0A:00:27:00:00:0E (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.0012s latency).
MAC Address: 08:00:27:00:FE:07 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up (0.0032s latency).
MAC Address: 08:00:27:0E:5F:8C (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.87 seconds
```

6. Full TCP Port Scan

A complete TCP port scan was performed against the authorized Metasploitable 2 target.

The following command was used:

```
nmap -p- -T4 192.168.56.102
```

The -p- option was used to scan the complete TCP port range, while -T4 was used as a faster timing template suitable for the isolated local lab environment.

The scan revealed numerous open ports and exposed services.

Examples of identified services included:

Port Service

21	FTP
22	SSH
23	Telnet
25	SMTP
53	DNS
80	HTTP
111	RPC
139	NetBIOS
445	SMB
1099	Java RMI
1524	Remote Shell Service

Port Service

2049 NFS

3306 MySQL

3632 distccd

5432 PostgreSQL

5900 VNC

6000 X11

8009 AJP

8180 HTTP/Tomcat

The presence of multiple exposed and legacy services increased the potential attack surface of the target system.

```
(sourabh@kali)~$ nmap -p- -T4 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-21 10:43 +0530
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 53.82% done; ETC: 10:43 (0:00:08 remaining)
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 53.89% done; ETC: 10:43 (0:00:08 remaining)
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 53.97% done; ETC: 10:43 (0:00:08 remaining)
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 54.05% done; ETC: 10:43 (0:00:08 remaining)
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 54.20% done; ETC: 10:43 (0:00:08 remaining)
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 54.66% done; ETC: 10:43 (0:00:08 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.018s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
41688/tcp open  unknown
42354/tcp open  unknown
43444/tcp open  unknown
56699/tcp open  unknown
MAC Address: 08:00:27:0E:5F:8C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 18.66 seconds
```

7. Service and Version Enumeration

After identifying open ports, service and version detection was performed.

The following command was used:

```
nmap -sV -sC -T4 192.168.56.102
```

The -sV option was used to identify service versions, while -sC executed Nmap's default enumeration scripts.

The scan identified several services and legacy software components.

Examples observed during enumeration included:

- vsFTPD 2.3.4
- OpenSSH 4.7p1
- Linux Telnet service
- Postfix SMTP
- ISC BIND DNS
- Apache HTTP Server 2.2.8
- Samba 3.0.20
- MySQL 5.0.51a
- PostgreSQL 8.3.x
- VNC
- Apache Tomcat 5.5
- Java RMI services

The presence of older software versions indicates that the target contains components that may contain known vulnerabilities and require further assessment.

```
sourabh@kali: ~
$ nmap -sV -sC -T4 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-21 10:44 +0530
Nmap scan report for 192.168.56.102
Host is up (0.0022s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp           vsftpd 2.3.4
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.56.101
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPD 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh           OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkeys:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:bl:24:3d:e8:f3 (RSA)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
|_ sslv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_     SSL2_DES_64_CBC_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2026-08-21T05:14:24+00:00; 0s from scanner time.
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain        ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind       2 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100003  2,3,4       2049/tcp   nfs
|_   100003  2,3,4       2049/udp   nfs
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login         OpenBSD or Solaris rlogind
514/tcp   open  shell         Netkit rshd
1099/tcp   open  java-rmi      GNU Classpath grmiregistry
1524/tcp   open  bindshell     Metasploitable root shell
2049/tcp   open  nfs           2-4 (RPC #100003)
2121/tcp   open  ftp           ProFTPD 1.3.1
3306/tcp   open  mysql         MySQL 5.0.51a-3ubuntu5
|_ mysql-info:
|_   Protocol: 10
|_   Version: 5.0.51a-3ubuntu5
|_   Thread ID: 8
|_   Capabilities flags: 43564
|_   Some Capabilities: Support41Auth, SupportsCompression, SupportsTransactions, LongColumnFlag, ConnectWithDatabase, Speaks41ProtocolNew, SwitchToSSLAfterHandshake
|_   Status: Autocommit
|_   Salt: IjZka-[S\Usg)4g,8I)
5432/tcp   open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ ssl-date: 2026-08-21T05:14:24+00:00; 0s from scanner time.
5900/tcp   open  vnc           VNC (protocol 3.3)
|_ vnc-info:
|_   Protocol version: 3.3
|_   Security types:
|_     VNC Authentication (2)
6000/tcp   open  X11           (access denied)
6667/tcp   open  irc           UnrealIRCd
8009/tcp   open  ajp13         Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTIONS request
8180/tcp   open  http          Apache Tomcat/Coyote JSP engine 1.1
|_ http-server-header: Apache-Coyote/1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:0E:5F:8C (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ smb-security-mode:
|_   account used: guest
|_   authentication level: user
|_   challenge response: supported
|_   message signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: 1h00m00s, deviation: 2h00m00s, median: 0s
|_ smb-os-discovery:
|_   OS: Unix (Samba 3.0.20-Debian)
|_   Computer name: metasploitable
|_   NetBIOS computer name:
|_   Domain name: localdomain
|_   FQDN: metasploitable.localdomain
|_   System time: 2026-08-21T01:14:16-04:00

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.73 seconds

(sourabh@kali)~$
```

8. Vulnerability Assessment Using Nmap

A vulnerability assessment was performed using Nmap NSE vulnerability scripts.

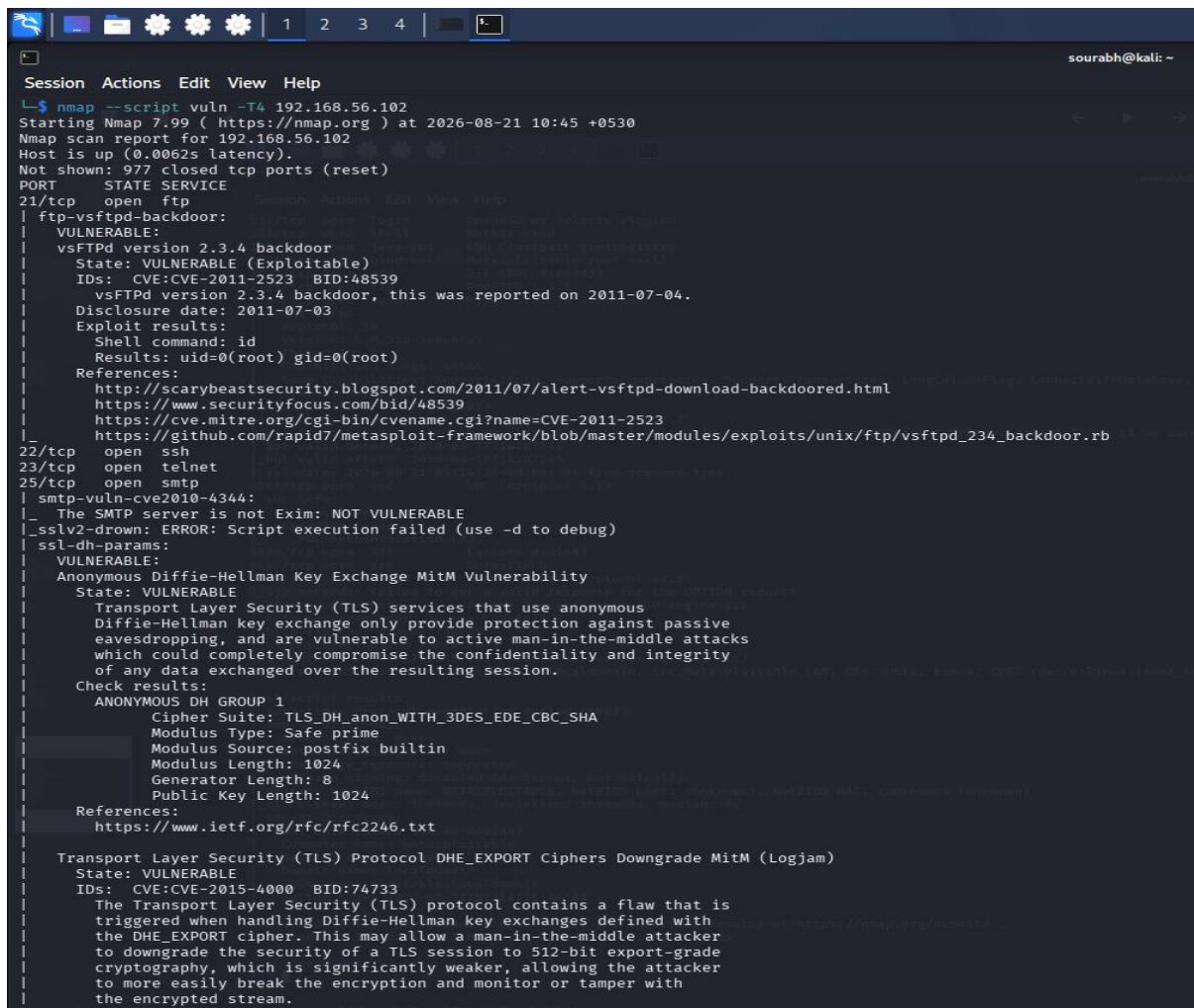
The following command was executed: `nmap --script vuln -T4 192.168.56.102`

The scan completed successfully against the authorized target.

Several potential vulnerabilities and security weaknesses were identified.

Important findings included:

- A vulnerability associated with vsFTPD 2.3.4
- SSL/TLS configuration weaknesses
- POODLE-related SSL/TLS vulnerability findings
- Weak Diffie-Hellman key exchange configuration
- Logjam-related findings
- Apache Slowloris denial-of-service susceptibility
- Java RMI-related vulnerability findings
- Additional exposed services and potentially vulnerable configurations



```
Session Actions Edit View Help
└─$ nmap --script vuln -T4 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-21 10:45 +0530
Nmap scan report for 192.168.56.102
Host is up (0.0062s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs: CVE:CVE-2011-2523 BID:48539
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   https://www.securityfocus.com/bid/48539
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| smtp-vuln-cve2010-4344:
|   The SMTP server is not Exim: NOT VULNERABLE
|_ sslv2-drown: ERROR: Script execution failed (use -d to debug)
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|   State: VULNERABLE
|   Transport Layer Security (TLS) services that use anonymous
|   Diffie-Hellman key exchange only provide protection against passive
|   eavesdropping, and are vulnerable to active man-in-the-middle attacks
|   which could completely compromise the confidentiality and integrity
|   of any data exchanged over the resulting session.
|   Check results:
|   ANONYMOUS DH GROUP 1
|   Cipher Suite: TLS_DH_anon_WITH_3DES_EDE_CBC_SHA
|   Modulus Type: Safe prime
|   Modulus Source: postfix builtin
|   Modulus Length: 1024
|   Generator Length: 8
|   Public Key Length: 1024
|   References:
|   https://www.ietf.org/rfc/rfc2246.txt
Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
State: VULNERABLE
IDS: CVE:CVE-2015-4000 BID:74733
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptology, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
```

```

| Disclosure date: 2015-5-19
| Check results:
|   EXPORT-GRADE DH GROUP 1
|     Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
|     Modulus Type: Safe prime
|     Modulus Source: Unknown/Custom-generated
|     Modulus Length: 512
|     Generator Length: 8
|     Public Key Length: 512
| References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
|   https://weakdh.org
|   https://www.securityfocus.com/bid/74733
|
| Diffie-Hellman Key Exchange Insufficient Group Strength
| State: VULNERABLE
|   Transport Layer Security (TLS) services that use Diffie-Hellman groups
|   of insufficient strength, especially those using one of a few commonly
|   shared groups, may be susceptible to passive eavesdropping attacks.
| Check results:
|   WEAK DH GROUP 1
|     Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
|     Modulus Type: Safe prime
|     Modulus Source: postfix builtin
|     Modulus Length: 1024
|     Generator Length: 8
|     Public Key Length: 1024
| References:
|   https://weakdh.org
|
| _ ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|     State: VULNERABLE
|     IDs: CVE:CVE-2014-3566 BID:70574
|     The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|     products, uses nondeterministic CBC padding, which makes it easier
|     for man-in-the-middle attackers to obtain cleartext data via a
|     padding-oracle attack, aka the "POODLE" issue.
|     Disclosure date: 2014-10-14
|     Check results:
|       TLS_RSA_WITH_AES_128_CBC_SHA
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|       https://www.securityfocus.com/bid/70574
|       https://www.imperialviolet.org/2014/10/14/poodle.html
|       https://www.openssl.org/~bodo/ssl-poodle.pdf
|
| 53/tcp open domain
| 80/tcp open http
| http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs: CVE:CVE-2007-6750
|     Slowloris tries to keep many connections to the target web server open and hold
|     them open as long as possible. It accomplishes this by opening connections to
|     the target web server and sending a partial request. By doing so, it starves
|     the http server's resources causing Denial Of Service.

```

```
1 2 3 4 5
Session Actions Edit View Help
| the http server's resources causing Denial Of Service.
| Disclosure date: 2009-09-17
| References:
| http://ha.ckers.org/slowloris/
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-dombased-xss: Couldn't find any DOM based XSS.
| http-enum:
| /tikiwiki/: Tikiwiki
| /test/: Test page
| /phpinfo.php: Possible information file
| /phpMyAdmin/: phpMyAdmin
| /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
| /icons/: Potentially interesting folder w/ directory listing
| /index/: Potentially interesting folder
|_ http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.102
| Found the following possible CSRF vulnerabilities:
|
| Path: http://192.168.56.102:80/dvwa/
| Form id:
| Form action: login.php
|
| Path: http://192.168.56.102:80/dvwa/login.php
| Form id:
| Form action: login.php
|
| Path: http://192.168.56.102:80/mutillidae/index.php?page=login.php
| Form id: idloginform
| Form action: index.php?page=login.php
|
| Path: http://192.168.56.102:80/mutillidae/?page=user-info.php
| Form id: id-bad-cred-tr
| Form action: ./index.php?page=user-info.php
|
| Path: http://192.168.56.102:80/mutillidae/index.php?page=register.php
| Form id: id-bad-cred-tr
| Form action: index.php?page=register.php
|
| Path: http://192.168.56.102:80/mutillidae/index.php?page=view-someones-blog.php
| Form id: id-bad-blog-entry-tr
| Form action: index.php?page=view-someones-blog.php
|
| Path: http://192.168.56.102:80/mutillidae/index.php?page=text-file-viewer.php
| Form id: id-bad-cred-tr
| Form action: index.php?page=text-file-viewer.php
|_ http-sql-injection: ERROR: Script execution failed (use -d to debug)
|_ http-trace: TRACE is enabled
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| 111/tcp open rpcbind
| 139/tcp open netbios-ssn
| 445/tcp open microsoft-ds
| 512/tcp open exec
| 513/tcp open login
| 514/tcp open shell
| 1099/tcp open rmiregistry
|_ rmi-vuln-classloader:
| 1920x1043 551.2 kB 84.9%
```

```
1 2 3 4 5
sourabh@kali: ~
Session Actions Edit View Help
| rmi-vuln-classloader:
| VULNERABLE:
| RMI registry default configuration remote code execution vulnerability
| State: VULNERABLE
| Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|
| References:
| https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
|_ ssl-ccs-injection: No reply from server (TIMEOUT)
5432/tcp open  postgresql
| ssl-ccs-injection:
| VULNERABLE:
| SSL/TLS MITM vulnerability (CCS Injection)
| State: VULNERABLE
| Risk factor: High
| OpenSSL before 0.9.8za, 1.0.0 before 1.0.0m, and 1.0.1 before 1.0.1h
| does not properly restrict processing of ChangeCipherSpec messages,
| which allows man-in-the-middle attackers to trigger use of a zero
| length master key in certain OpenSSL-to-OpenSSL communications, and
| consequently hijack sessions or obtain sensitive information, via
| a crafted TLS handshake, aka the "CCS Injection" vulnerability.
|
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
| http://www.cvedetails.com/cve/2014-0224
| http://www.openssl.org/news/secadv_20140605.txt
|_ ssl-poodle:
| VULNERABLE:
| SSL POODLE information leak
| State: VULNERABLE
| IDs: CVE:CVE-2014-3566 BID:70574
| The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
| products, uses nondeterministic CBC padding, which makes it easier
| for man-in-the-middle attackers to obtain cleartext data via a
| padding-oracle attack, aka the "POODLE" issue.
| Disclosure date: 2014-10-14
| Check results:
| TLS_RSA_WITH_AES_128_CBC_SHA
| References:
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
| https://www.securityfocus.com/bid/70574
| https://www.imperialviolet.org/2014/10/14/poodle.html
| https://www.openssl.org/~bodo/ssl-poodle.pdf
|_ ssl-dh-params:
| VULNERABLE:
| Diffie-Hellman Key Exchange Insufficient Group Strength
| State: VULNERABLE
| Transport Layer Security (TLS) services that use Diffie-Hellman groups
| of insufficient strength, especially those using one of a few commonly
| shared groups, may be susceptible to passive eavesdropping attacks.
| Check results:
| WEAK DH GROUP 1
| Cipher Suite: TLS_DHE_RSA_WITH_AES_128_CBC_SHA
| Modulus Type: Safe prime
```

```
Session Actions Edit View Help
| Modulus Type: Safe prime
| Modulus Source: Unknown/Custom-generated
| Modulus Length: 1024
| Generator Length: 8
| Public Key Length: 1024
| References:
| https://weakdh.org
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
|_irc-unrealircd-backdoor: Looks like trojaned version of unrealircd. See http://seclists.org/fulldisclosure/2010/Jun/277
8009/tcp open ajp13
8180/tcp open unknown
http-cookie-flags:
/admin/:
JSESSIONID:
httponly flag not set
/admin/index.html:
JSESSIONID:
httponly flag not set
/admin/login.html:
JSESSIONID:
httponly flag not set
/admin/admin.html:
JSESSIONID:
httponly flag not set
/admin/account.html:
JSESSIONID:
httponly flag not set
/admin/admin_login.html:
JSESSIONID:
httponly flag not set
/admin/home.html:
JSESSIONID:
httponly flag not set
/admin/admin-login.html:
JSESSIONID:
httponly flag not set
/admin/adminLogin.html:
JSESSIONID:
httponly flag not set
/admin/controlpanel.html:
JSESSIONID:
httponly flag not set
/admin/cp.html:
JSESSIONID:
httponly flag not set
/admin/index.jsp:
JSESSIONID:
httponly flag not set
/admin/login.jsp:
JSESSIONID:
httponly flag not set
/admin/admin.jsp:
JSESSIONID:
httponly flag not set
/admin/home.jsp:
JSESSIONID:
Screenshot: 1024x768 30 ppg 1920x1043 346.7kB 84.3%
```

```
Session Actions Edit View Help
| JSESSIONID:
| httponly flag not set
| /admin/admin_login.jsp:
| JSESSIONID:
| httponly flag not set
| /admin/adminLogin.jsp:
| JSESSIONID:
| httponly flag not set
| /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html:
| JSESSIONID:
| httponly flag not set
| /admin/includes/FCKeditor/editor/filemanager/upload/test.html:
| JSESSIONID:
| httponly flag not set
| /admin/jscript/upload.html:
| JSESSIONID:
| httponly flag not set
|_http-slowloris-check:
| VULNERABLE:
| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDS: CVE:CVE-2007-6750
| Slowloris tries to keep many connections to the target web server open and hold
| them open as long as possible. It accomplishes this by opening connections to
| the target web server and sending a partial request. By doing so, it starves
| the http server's resources causing Denial Of Service.
| Disclosure date: 2009-09-17
| References:
| http://ha.ckers.org/slowloris/
```

```
Session Actions Edit View Help
| JSESSIONID:
| httponly flag not set
| /admin/jscrip/upload.html:
| JSESSIONID:
| httponly flag not set
| http-slowloris-check:
| VULNERABLE:
| Slowloris DOS attack
| State: LIKELY VULNERABLE
| IDs: CVE:2007-6750
| Slowloris tries to keep many connections to the target web server open and hold
| them open as long as possible. It accomplishes this by opening connections to
| the target web server and sending a partial request. By doing so, it starves
| the http server's resources causing Denial Of Service.
|
| Disclosure date: 2009-09-17
| References:
| http://ha.ckers.org/slowloris/
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
| http-enum:
| /admin/: Possible admin folder
| /admin/index.html: Possible admin folder
| /admin/login.html: Possible admin folder
| /admin/admin.html: Possible admin folder
| /admin/account.html: Possible admin folder
| /admin/admin_login.html: Possible admin folder
| /admin/home.html: Possible admin folder
| /admin/admin-login.html: Possible admin folder
| /admin/adminLogin.html: Possible admin folder
| /admin/controlpanel.html: Possible admin folder
| /admin/cp.html: Possible admin folder
| /admin/index.jsp: Possible admin folder
| /admin/login.jsp: Possible admin folder
| /admin/admin.jsp: Possible admin folder
| /admin/home.jsp: Possible admin folder
| /admin/controlpanel.jsp: Possible admin folder
| /admin/admin-login.jsp: Possible admin folder
| /admin/cp.jsp: Possible admin folder
| /admin/account.jsp: Possible admin folder
| /admin/admin_login.jsp: Possible admin folder
| /admin/adminLogin.jsp: Possible admin folder
| /manager/html/upload: Apache Tomcat (401 Unauthorized)
| /manager/html: Apache Tomcat (401 Unauthorized)
| /admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File upload
| /admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
| /admin/jscrip/upload.html: Lizard Cart/Remote File upload
| /webdav/: Potentially interesting folder
| MAC Address: 08:00:27:0E:5F:8C (Oracle VirtualBox virtual NIC)
|
| Host script results:
| _smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)
| _smb-vuln-ms10-054: false
| _smb-vuln-ms10-061: false
|
| Nmap done: 1 IP address (1 host up) scanned in 320.75 seconds
|
| (sourabh@kali)~$
```

The Nmap vulnerability scan results were treated as security findings requiring validation and analysis. Automated scan output alone was not considered sufficient to claim that every potential finding was fully exploitable.

9. Web Server Vulnerability Assessment Using Nikto

A web vulnerability scan was performed against the HTTP service running on the target.

The following command was used:

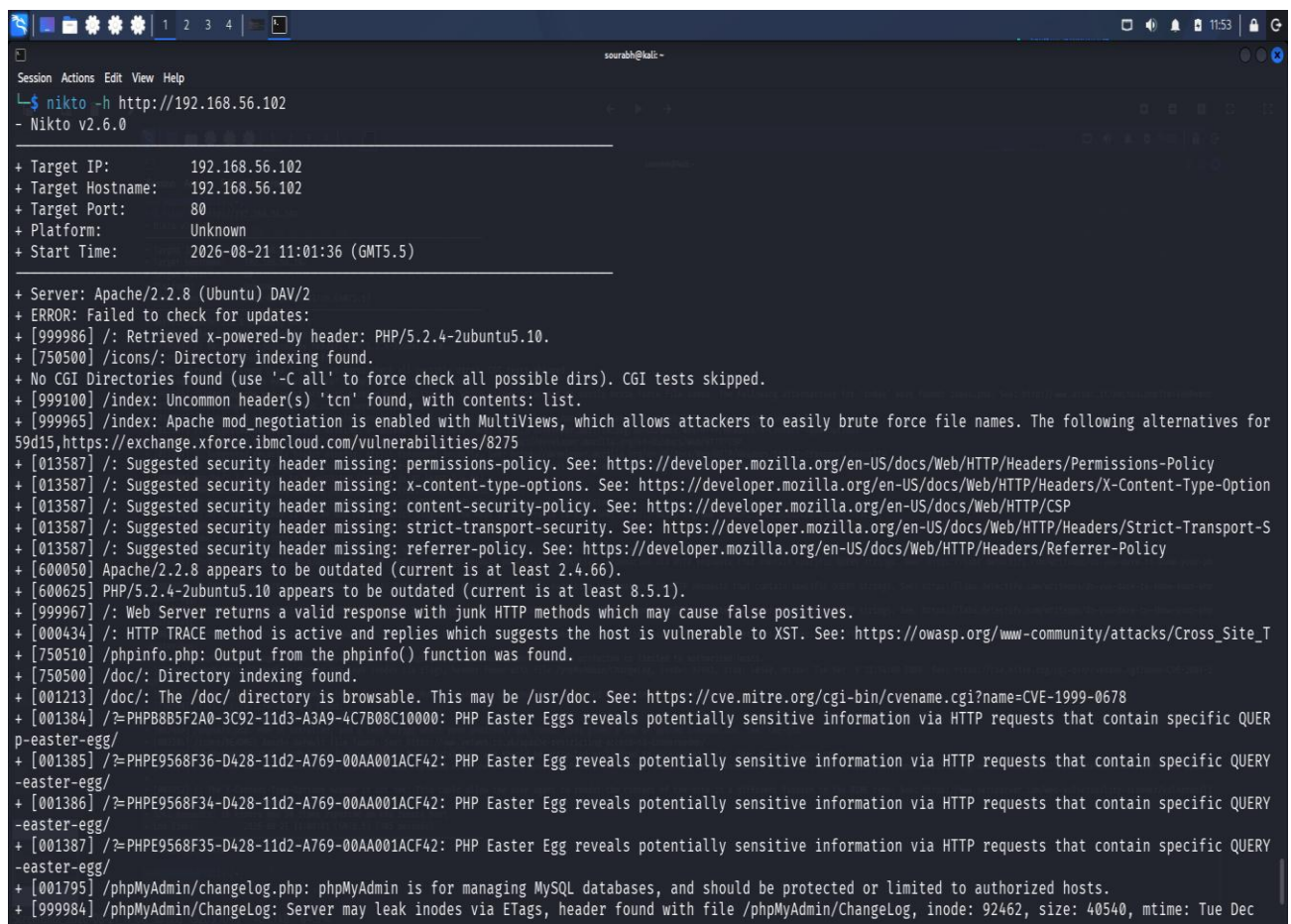
```
nikto -h http://192.168.56.102
```

Nikto scanned the web server running on port 80 and identified multiple security-related findings.

The assessment identified issues including:

- Directory indexing
- Missing or weak HTTP security headers
- Exposure of server and technology information
- An exposed phpinfo() page
- Potentially sensitive files or directories
- Legacy web server and PHP components
- HTTP methods and configurations requiring review

These findings demonstrate that insecure web server configuration and unnecessary information exposure can increase the risk to a web application.



```
Session Actions Edit View Help
$ nikto -h http://192.168.56.102
- Nikto v2.6.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-08-21 11:01:36 (GMT5.5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates:
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Option
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-S
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_T
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?PHPBB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUER
p-easter-egg/
+ [001385] /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY
-easter-egg/
+ [001386] /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY
-easter-egg/
+ [001387] /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY
-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec
```

```
Session Actions Edit View Help
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Option
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-S
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_T
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?PHPBB85F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUER
p-easter-egg/
+ [001385] /?PHPPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY
-easter-egg/
+ [001386] /?PHPPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY
-easter-egg/
+ [001387] /?PHPPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY
-easter-egg/
+ [001795] /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [999984] /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec
418
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: htt
s
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the M
ties/missing-content-type-header/
+ 8242 requests: 16 errors and 30 items reported on the remote host
+ End Time: 2026-08-21 11:08:01 (GMT5.5) (385 seconds)

+ 1 host(s) tested
```

10. Summary of Key Findings

The following table summarizes the major findings from the assessment.

ID	Finding	Tool	Risk Level
V-01	vsFTPD 2.3.4 vulnerability finding	Nmap	High
V-02	Multiple exposed legacy services	Nmap	High
V-03	Weak SSL/TLS configuration findings	Nmap	Medium
V-04	POODLE-related vulnerability finding	Nmap	Medium
V-05	Weak Diffie-Hellman / Logjam-related finding	Nmap	Medium
V-06	Slowloris denial-of-service susceptibility	Nmap	Medium
V-07	Java RMI-related vulnerability finding	Nmap	High
V-08	Directory indexing enabled	Nikto	Medium
V-09	Missing HTTP security headers	Nikto	Medium
V-10	phpinfo() page exposed	Nikto	Medium
V-11	Server/version information disclosure	Nikto	Low

ID	Finding	Tool	Risk Level
V-12	Potentially sensitive files/directories	Nikto	Medium

Risk levels were assigned based on the potential impact of the issue and the exposure observed in the authorized lab environment.

11. Security Risks

11.1 Exposed and Legacy Services

The target system exposed a large number of network services, including FTP, Telnet, SMB, databases, remote access services, and web services.

Exposing unnecessary services increases the attack surface of a system. Older or unsupported services may also contain publicly known vulnerabilities.

Risk: High

11.2 FTP Service Vulnerability Finding

The Nmap scan identified a vulnerability associated with the detected vsFTPd 2.3.4 service.

An insecure or vulnerable remote-access service can potentially lead to unauthorized access if the vulnerability is successfully exploited.

Risk: High

11.3 Weak SSL/TLS Configuration

The vulnerability scan reported multiple SSL/TLS-related weaknesses, including findings related to weak cryptographic configurations.

Weak encryption can reduce the confidentiality and integrity of network communication.

Risk: Medium

11.4 Slowloris Denial-of-Service Susceptibility

The web server scan identified a potential Slowloris denial-of-service issue.

This type of weakness may allow a malicious client to consume server resources through multiple incomplete requests, potentially affecting the availability of the web service.

Risk: Medium

11.5 Directory Indexing

Nikto identified directory indexing on the target web server.

Directory indexing can expose files, folders, backup files, or other information that should not be publicly accessible.

Risk: Medium

11.6 Missing Security Headers

The web server was found to be missing recommended HTTP security headers.

Security headers can help browsers enforce additional protections against certain web-based attacks and unsafe content handling.

Risk: Medium

11.7 phpinfo() Exposure

The presence of a phpinfo() page may expose information about the server configuration, PHP modules, environment variables, and software versions.

This information could assist an attacker during reconnaissance.

Risk: Medium

12. Recommendations and Mitigation

12.1 Disable Unnecessary Services

Services that are not required for normal operation should be disabled.

Examples may include legacy remote access services or unused network services.

This reduces the overall attack surface.

12.2 Apply Security Updates

Operating systems, web servers, databases, and other software should be regularly updated.

Outdated components should be upgraded or replaced with supported versions.

12.3 Replace Insecure Protocols

Legacy protocols should be replaced with more secure alternatives where possible.

For example, secure remote administration protocols should be preferred over insecure plaintext services.

12.4 Strengthen SSL/TLS Configuration

Weak SSL/TLS protocols and cryptographic configurations should be disabled.

The server should use modern TLS configurations and strong cryptographic settings.

12.5 Disable Directory Listing

Directory indexing should be disabled unless there is a specific business or application requirement.

Sensitive directories should also have appropriate access controls.

12.6 Implement HTTP Security Headers

Appropriate security headers should be configured based on the requirements of the application.

Examples include:

- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options

12.7 Remove Sensitive Information Pages

Pages such as `phpinfo()` should not be publicly accessible on production systems.

Unnecessary information disclosure should be removed to limit reconnaissance opportunities.

12.8 Perform Regular Vulnerability Assessments

Regular vulnerability scanning and security assessments should be conducted to identify newly introduced weaknesses.

Critical and high-risk findings should be prioritized for remediation and verification.

13. Conclusion

This task demonstrated a basic vulnerability assessment workflow using Kali Linux, Nmap, Nmap NSE scripts, and Nikto.

The assessment began with network configuration and connectivity testing, followed by host discovery, full TCP port enumeration, and service/version detection. The vulnerability assessment identified multiple exposed services, legacy software components, SSL/TLS weaknesses, web server configuration issues, and other potential security risks.

The results demonstrate the importance of reducing unnecessary network exposure, keeping software updated, using secure configurations, and performing regular security assessments.

All testing was conducted against an intentionally vulnerable Metasploitable 2 virtual machine within an isolated and authorized VirtualBox Host-Only network for educational purposes.
